地政学的変動下におけるサイバーセキュリティ公共財の持続性評価：脆弱性情報・悪用観測・リスク優先順位付け機能の依存構造分析

井上 圭[1]

概要：CVE、NVD、KEV Catalog などの脆弱性情報基盤は、脆弱性管理やインシデント対応を広く支える公共的基盤となっている。一方、NVD の処理遅延や運営体制の変化、EUVD など地域的基盤の整備、リスクベース脆弱性管理への移行、フロンティア AI による情報処理の高速化などにより、これらの基盤の持続性と依存構造を改めて捉える必要が生じている。

本研究では、脆弱性管理を支える公共的基盤を、脆弱性識別、製品・資産対応付け、技術評価、情報エンリッチメント、悪用観測、悪用可能性予測、リスク優先順位付け・意思決定支援、情報流通・機械可読交換の 8 機能に整理する。さらに、機能間、基盤間、提供主体への依存を区別し、利用範囲、機能的重要性、提供継続性、主体集中度、代替可能性、相互運用性の 6 軸から、CVE、CPE、CVSS、NVD、KEV Catalog、EPSS、EUVD、JVN iPedia の 8 対象へ試行的に適用した。その結果をもとに、残存性と代替可能性の違い、共通の上流基盤への依存、地域的・制度的補完の限界を整理し、日本において必要となる国内保持、国際接続、国内補完及び縮退運用の組合せについて考察する。

キーワード：脆弱性管理、サイバーセキュリティ公共財、依存構造、持続性、地政学的変動

Sustainability Assessment of Cybersecurity Public Goods under Geopolitical Change: Analyzing Dependencies in Vulnerability Information, Exploitation Intelligence, and Risk Prioritization

INOUE Kei

Abstract: Vulnerability information infrastructures such as CVE, NVD, and the Known Exploited Vulnerabilities (KEV) Catalog have become public infrastructure supporting vulnerability management and incident response. However, processing delays and operational changes in NVD, the development of regional infrastructures such as the European Vulnerability Database (EUVD), the shift toward risk-based vulnerability management, and faster information processing enabled by frontier AI have increased the need to reconsider the sustainability and dependency structures of these infrastructures.

This study organizes the public infrastructure supporting vulnerability management into eight functions: vulnerability identification, product and asset mapping, technical assessment, information enrichment, exploitation observation, exploitation probability prediction, risk prioritization and decision support, and information distribution and machine-readable exchange. It further distinguishes dependencies among functions, infrastructures, and providers, and applies six evaluation dimensions—scope of use, functional importance, continuity of provision, concentration of control, substitutability, and interoperability—to eight targets: CVE, CPE, CVSS, NVD, the KEV Catalog, EPSS, EUVD, and JVN iPedia. Based on this exploratory application, the study examines the distinction between persistence and substitutability, dependencies on shared upstream resources, and the limits of regional and institutional alternatives, and discusses the combination of domestic retention, international connectivity, domestic supplementation, and degraded-mode operation required for resilience in Japan.

Keywords: Vulnerability Management, Cybersecurity Public Goods, Dependency Structure, Sustainability, Geopolitical Change

1. はじめに

現代の脆弱性管理は、個々の組織が自ら収集した情報だけで完結するものではなく、脆弱性識別、製品との対応付け、技術評価、情報エンリッチメント、悪用情報、悪用可能性予測、機械可読な取得・流通等を担う複数の識別体系、標準、データベース、評価情報及びサービスの組合せに依存している。

これらの基盤は多数の組織によって共同利用され、新規提

1 株式会社ラック 脅威分析グループ
Threat Analysis Group, LAC Co.,Ltd.
kei.inoue@lac.co.jp

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

供・更新の停止、遅延、網羅性や品質の低下、機械可読形式による配信の喪失、アクセス条件の変更等が、個別組織を越えて下流の製品、サービス及び運用へ波及し得る。そのため、単なる公開情報源の集合ではなく、脆弱性管理を支える公共的基盤として捉える必要がある。本研究では、多数の主体が共同利用し、その利用可能性、品質及び継続性が個別組織を越えて影響する情報、識別体系、標準、データベース、サービス等を、「サイバーセキュリティ公共財」と呼ぶ。ただし、これは経済学上の厳密な公共財と同一視するものではない。

著者の前年研究では、NVD への依存、各国・地域の脆弱性情報基盤、脆弱性の評価・優先順位付けに用いられる主要な情報源や標準を比較し、単一基盤による完全代替ではなく複数基盤による補完が必要であることを示した[1]。一方、情報源やサービスの名称を単位とした比較だけでは、一つの基盤が担う複数機能、共通の上流基盤への依存、運営・意思決定を担う提供主体、停止・劣化時の影響経路を十分に区別できない。政策、予算、制度、アクセス条件又は国際関係の変化が提供継続へ影響し得る状況では、基盤名称ではなく、機能、依存関係及び持続性から分析する必要がある。

そこで本研究は、既存の公共的基盤を機能単位で整理し、機能間、基盤間、提供主体への依存関係を分析するとともに、停止・劣化時の持続性を公共的基盤として評価する観点を整理し、既存基盤へ試行的に適用する。本研究の研究課題（Research Question：RQ）を次のとおり設定する。

RQ1：脆弱性管理を支える公共的基盤は、どのような機能から構成されるか。
RQ2：各機能およびそれを提供する基盤の間には、どのような依存関係が存在するか。
RQ3：脆弱性管理を支える基盤を、公共的基盤としてどのような観点から評価できるか。

詳細評価では、CVE、Official CPE Dictionary、CVSS、NVD、Known Exploited Vulnerabilities（KEV）Catalog、EPSS、European Vulnerability Database（EUVD）及び JVN iPedia の 8 対象を扱う。対象の選定理由と評価方法は後章で示す。本研究は新規フレームワークの発明を主張するものではなく、既存基盤を機能、依存関係及び持続性の観点から整理して試行評価する探索的研究である。名称単位の比較を機能単位へ拡張し、機能間、基盤間、提供主体への依存関係と持続性を一体として扱う手順を示し、その有効性と限界を検討する。また、日本が独自に維持すべき機能、国際的に共同維持すべき機能、代替性・補完性を高めるべき機能を考察するための基礎とする。

本稿において、調査基準日はすべて 2026 年 08 月 05 日とする。

2. 脆弱性管理を支える公共的基盤の変化

2.1 公共的脆弱性基盤の変化

前年研究以降、脆弱性管理を支える公共的基盤では、運営継続、処理能力、制度及び地域的な供給経路に変化が生じた。NVD では、2024 年以降に CVE の分析・エンリッチメント遅延とバックログが顕在化し、2026 年には KEV 掲載 CVE や重要ソフトウェア等を優先するリスク基準のエンリッチメントへ移行した[2] [3]。これは NVD 全体の停止ではなく、処理能力の配分と提供内容の変更であり、持続性評価では稼働の有無だけでなく適時性、網羅性及び提供機能の変化を捉える必要がある。

CVE Program では、2025 年 04 月に MITRE の運営契約が満了直前となり、CISA のオプション行使で中断が回避された。同時期には、長期的な存続、安定性及び独立性を目的とする CVE Foundation 設立も発表された[4] [5]。ただし、運営主体又は技術的支配権限が同財団へ全面移管されたとは扱わない。重要なのは、世界的な識別基盤の継続が契約、スポンサー及びガバナンスと接続している点である。

EU では EUVD が 2025 年に正式運用を開始し、CSIRT、ベンダ及び既存データベース等の情報を集約する地域的・制度的基盤が加わった[6]。一方、CVE や KEV 等の既存上流情報を利用するため、地域的供給経路の多様化が共通の上流基盤への依存解消を意味するわけではない。日本では JVN 及び JVN iPedia が国内外の脆弱性対策情報を日本語で蓄積・公開し、機械利用も継続している[7] [8]。

以上から、公共的基盤の持続性は、各基盤が担う機能、上流情報・標準・提供主体への依存、停止・劣化時の影響経路を区別して捉える必要がある。

2.2 リスクベース脆弱性管理への移行

脆弱性対応の優先順位付けは単一の数値では完結しない。CVSS は技術的特性と深刻度を表し[9]、KEV Catalog は確認済みの実環境での悪用を示す[10]。EPSS は公開済み CVE の将来の悪用可能性を日次で推定するが、組織固有の資産重要度や業務影響までは評価せず[11]、SSVC 等はこれらと組織固有情報を組み合わせて対応判断を支援する[12]。

したがって、現在の脆弱性管理は、CVE による共通識別を基礎に、CVSS、KEV、EPSS、製品・資産情報、業務影響等を結合して組織の意思決定へ接続する構造として理解でき

© 2026 Information Processing Society of Japan

る。CISA の BOD 26-04 や NVD への SSVC 関連情報追加は、このリスクベース化が制度及び配信項目にも表れている例である [3] [13]。上流の識別子、評価情報、エンリッチメント又は機械可読配信の遅延・劣化は、複数情報を結合する下流の優先順位判断へ波及し得る。

2.3 フロンティア AI がもたらす環境変化

AI によるコード解析、脆弱性発見、成立確認及び修正案生成の一部では高速化・自動化が進展している。例えば、Big Sleep による実在ソフトウェアの脆弱性発見や、AI Cyber Challenge における脆弱性発見・修正の成果が報告されている[14] [15]。ただし、これらは対象や評価環境に依存し、現実の攻撃全般が自動化されたことを意味しない。

本研究では AI を独立した評価対象又は第 7 の評価軸とはせず、情報の探索・解析・結合の高速化により、公共的基盤へ適時性、品質、参照可能性、機械可読性及び継続性をより強く要求する背景要因として扱う。自動処理が上流データを反復利用するほど、誤り、遅延、欠落又は形式変更も下流へ短時間で伝播し得る。

2.4 環境変化と研究課題の接続

以上の変化を踏まえ、本研究では基盤名称ではなく機能を分け、機能間・基盤間・提供主体への依存を把握し、停止・劣化時にも必要な機能がどこまで維持されるかを評価する。第 3 章では、そのための評価対象、機能分類、依存関係及び評価方法を示す。

3. 評価対象と研究方法

本章では、第 1 章の RQ1～RQ3 に対応し、第 4 章の評価結果を理解・検証するため、評価対象と評価単位、公共的機能、三層の依存関係、停止・劣化シナリオ、6 評価軸及び評価手順を示す。

3.1 サイバーセキュリティ公共財の定義

本研究では、脆弱性管理において多数の主体が共同利用し、その利用可能性、品質及び継続性が個別組織を越えて影響する情報、識別体系、標準、データベース、サービス及び関連基盤を、「サイバーセキュリティ公共財」と呼ぶ。これは経済学上の厳密な公共財ではなく、共通利用され、その停止・劣化が広範な下流へ波及し得る公共的性格に着目した概念である。

3.2 評価対象と評価単位

評価対象候補は、公共アクセス性、利用の広がり、共通基盤性、再利用・共有可能性及び研究範囲への適合性から選定した。詳細評価は、CVE Program、Official CPE Dictionary、CVSS、NVD、Known Exploited Vulnerabilities（KEV）Catalog、Exploit Prediction Scoring System （ EPSS ）、 European Vulnerability Database（EUVD）、JVN iPedia の 8 対象へ適用する。評価単位（Unit）には、識別子として「U-」を付与する。

3.3 公共的機能と依存関係

RQ1 に対しては、各基盤を名称ではなく入出力及び運用上の役割から表 3-1 の 8 機能へ対応付ける。一つの基盤は複数機能を担い得るため、機能分類と補助評価単位への分解は別に判断する。

表 3-1 公共的機能の分類

機能	定義
脆弱性識別	脆弱性へ一意の識別子を付与し、主体間で同一対象を参照可能にする
製品・資産対応付け	脆弱性情報を製品、版、構成要素又は組織資産へ結び付ける
技術評価	技術的深刻度、攻撃条件及び影響を共通の尺度・表現で示す
情報エンリッチメント	識別情報へ製品、影響、参照、弱点分類等の情報を付加する
悪用観測	現実環境で確認された悪用又は関連攻撃活動を提示する
悪用可能性予測	一定期間内の悪用可能性を推定する
リスク優先順位付け・意思決定支援	悪用情報、資産、影響等を組み合わせ、対応優先順位や行動選択を支援する
情報流通・機械可読交換	識別子、標準形式、API、フィード等により情報を主体・システム間で流通させる

RQ2 に対しては、依存を機能間、基盤間、提供主体への依存の三層で捉える。上流データや既存仕様の残存と、付加、選定、推定、訂正、新規採番又は公式公開の継続は区別する。

3.4 停止・劣化シナリオと 6 軸評価

停止・劣化は、サービス名称ではなく評価単位ごとの中核機能へ適用し、共通シナリオを表 3-2 の S1～S7 とする。

表 3-2 停止・劣化シナリオ

ID	シナリオ
S1	全面利用停止
S2	新規提供・更新停止
S3	適時性劣化

© 2026 Information Processing Society of Japan

S4	網羅性劣化
S5	品質・一貫性劣化
S6	配信・相互運用性劣化
S7	アクセス制約・供給範囲縮小

S1 は最大影響、ローカル複製及び完全代替を確認するストレスシナリオとし、通常の H/M/L 判定は S2～S7 を中心とする。既存仕様・データの残存と、新規提供・更新・訂正・推定・配信の継続は区別する。

RQ3 に対しては表 3-3 の 6 軸を用いる。

表 3-3 6 軸評価

評価軸	評価する項目
利用範囲	独立した主体、地域、制度又は下流へ採用される広がり
機能的重要性	停止・劣化による下流工程への固有の影響
提供継続性	通常周期で提供し、劣化時に復旧・代行・承継できる体制
主体集中度	不可欠工程、公式性の確定、承認又は最終権限の支配領域への集中
代替可能性	同じ障害原因に巻き込まれない既存手段による中核機能の置換可能性
相互運用性	識別子、意味、形式及び版を保った交換、併用又は切替えの可能性

各軸は High / Medium / Low で独立に判定し、必要な根拠が不足するか解消不能に相反する場合は Unknown、論理的に参照対象がない場合は Not Applicable とする。根拠不足を Medium で代用しない。H/M/L は数値化せず、単純加算、平均、重み付け、総合点又は総合ランクを設けない。地政学的耐性も独立した第 7 軸とはせず、供給制約時の持続性を各軸と停止・劣化時の影響経路から横断的に解釈する。

3.5 根拠と評価手順

評価対象の状態は 2026 年 08 月 05 日時点にそろえ、資料の時点と適用範囲を確認した。資料が直接支持する内容を確認事実とし、評価条件への接続を推論として分離する。公開情報が見つからないことを「存在しない」と扱わず、必要な根拠が不足する場合は推測で判定を埋めない。

各評価単位・軸について、独立した 2 系列の評価（Evaluation : EV-01、EV-02）を行い、相互の判定を参照せず、確認事実、判定理由、適用シナリオ、残存機能及び不確実性を記録した。その後、両系列の判定、差分及び根拠を照合する工程を「合議」とし、必要な制約を整理したうえで最終判定を確定した。

4. 既存基盤への適用

本章では、第 3 章で定めた方法を CVE Program、Official CPE Dictionary、CVSS、NVD、Known Exploited Vulnerabilities（KEV）Catalog、Exploit Prediction Scoring System（EPSS）、European Vulnerability Database（EUVD）及び JVN iPedia の 8 対象へ適用した結果を示す。対象別の詳細な根拠及び合議過程は省略し、評価単位の分解が結果解釈に関係する代表例と、合議後の最終評価結果を示す。

4.1 適用対象と評価単位

評価は原則として基盤を基本評価単位とし、一体評価では依存構造、停止時の挙動、残存機能又は代替可能性等の重要な差が失われる場合に限り、補助評価単位へ分解した。その結果、CVE、NVD、EPSS の 3 対象に補助評価単位を設け、8 対象を計 14 評価単位として評価した。補助評価単位は独立したサービスを意味するものではなく、同一基盤内部の異なる機能特性を保持するための分析上の分解である。

4.2 代表的な適用結果

CVE Program は共通識別を担う上流基盤であり[16]、U-CVE-BASE に加え、既存 ID・レコード・スキーマ等の参照を扱う U-CVE-SPEC と、新規採番・公式公開・訂正等を扱う U-CVE-OPS に分解した[17] [18] [19] [20]。既存情報の残存と新規採番・公式更新の継続は同一ではなく、3 評価単位の主体集中度はいずれも Unknown となった。

NVD は CVE レコードを入力として付加情報を生成・訂正し、外部由来情報と統合・配信する基盤である[21] [3]。U-NVD-BASE、付加情報生成を扱う U-NVD-ENRICH、統合・配信を扱う U-NVD-DIST に分解した[22] [23]。3 評価単位の 6 軸評価値は同一であるが、停止時の残存機能と依存構造が異なるため補助評価単位を維持した。

EPSS は公開済み CVE の悪用可能性を日次で予測・提供する基盤であり[24] [11]、U-EPSS-BASE、モデル・方法論を扱う U-EPSS-MODEL、日次生成・配信を扱う U-EPSS-OPS に分解した[25] [26]。最終評価では MODEL の利用範囲が Unknown、代替可能性及び相互運用性が Low となり、BASE 及び OPS と結果が分かれた。これは同一基盤内部でも持続性上の特性が異なり得る例である。

EUVD と JVN iPedia は、共有する上流情報を利用しつつ地域的・制度的又は言語的な補完機能を提供する。EUVD の相互運用性は Unknown、JVN iPedia の利用範囲は Medium となった[6] [27] [28] [8]。いずれも上流情報の残存だけでは、各

© 2026 Information Processing Society of Japan

基盤固有の統合・整理・配信機能の継続を意味しない。

4.3 最終評価結果

表 4-1 に、EV-01 及び EV-02 の独立評価後、両系列の差分と根拠を照合する合議を経て確定した 8 対象・14 評価単位の最終結果を示す。補助評価単位を持つのは CVE、NVD、EPSS である。Unknown は CVE の主体集中度 3 評価単位、EPSS MODEL の利用範囲、EUVD の相互運用性に残り、Not Applicable は 0 件であった。各軸は独立した特性として扱い、H/M/L を総合点、平均、順位又は総合ランクへ変換しない。

表 4-1 8 対象の評価単位別 6 軸評価結果

対象	単位	利用範囲	機能的重要性	提供継続性	主体集中度	代替可能性	相互運用性
CVE	U-CVE-BASE	H	H	M	Unknown	M	H
CVE	U-CVE-SPEC	H	M	M	Unknown	M	H
CVE	U-CVE-OPS	H	H	M	Unknown	M	H
CPE	U-CPE-BASE	H	M	M	H	M	H
CVSS	U-CVSS-BASE	H	M	M	H	M	H
NVD	U-NVD-BASE	H	M	M	H	M	H
NVD	U-NVD-ENRICH	H	M	M	H	M	H
NVD	U-NVD-DIST	H	M	M	H	M	H
KEV	U-KEV-BASE	H	M	M	H	M	H
EPSS	U-EPSS-BASE	H	M	M	H	M	H
EPSS	U-EPSS-MODEL	Unknown	M	M	H	L	L
EPSS	U-EPSS-OPS	H	M	M	H	M	H
EUVD	U-EUVD-BASE	H	M	M	H	M	Unknown
JVN iPedia	U-JVNI-BASE	M	M	M	H	M	H

本章では、対象別の評価根拠を網羅的に再掲せず、補助評価単位と非評価結果が結果解釈に与える差を代表例として示した。これらの対象横断的な意味は第 5 章で考察する。

5. 考察

5.1 脆弱性管理を支える公共的機能の構造

第 4 章の結果を第 3 章で定めた 8 機能から横断すると、脆弱性管理を支える公共的基盤は、同種の情報源が並列に存在するのではなく、脆弱性識別、製品・資産対応付け、技術評価、情報エンリッチメント、悪用観測、悪用可能性予測、リスク優先順位付け・意思決定支援、情報流通・機械可読交換が連鎖する分業構造として理解できる。8 対象と 8 機能は一対一には対応せず、一つの基盤が複数機能を担う場合があり、一つの機能も複数基盤によって異なる形で支えられ得る。

この連鎖では、CVE 等の共通識別が、技術評価、悪用観測、悪用可能性予測、エンリッチメント等の異質な情報を同一脆弱性へ接続する。CVSS、KEV Catalog、EPSS は、それぞれ技術的深刻度、確認済み悪用、将来の悪用可能性という異なる意味を持ち、相互に置き換えられる単一のリスクスコアではない。製品・資産対応付けはこれらを実環境へ結び付け、最終的な優先順位判断は組織固有情報と下流で結合されて成立する。また、情報流通・機械可読交換は特定の一基盤に閉じず、識別、評価、観測、予測及びエンリッチメントを横断して接続する機能である。

したがって RQ1 に対して重要なのは、基盤名の数ではなく、複数の公共的機能が分業しながら相互接続していることである。この機能構造は、機能が複数実装されていること自体が独立性又は代替可能性を意味しないことも示して

© 2026 Information Processing Society of Japan

いる。

5.2 機能・基盤・提供主体にまたがる依存構造

第 4 章の依存関係を横断すると、依存は機能間、基盤間、提供主体への依存の三層で現れる。異なる機能が共通識別等の上流機能を前提とし、具体的な基盤は識別子、データ、標準、スキーマ又は配信経路に依存し、さらに公式性の付与、選定、更新、統合及び公開は特定の提供主体や支配領域に依存し得る。したがって、基盤数や参加主体数だけから依存が分散しているとは判断できない。

共有依存の代表は CVE ID であり、NVD、KEV Catalog、EPSS、EUVD、JVN iPedia 等は異なる機能を持ちながら同一脆弱性を結合する共通参照点として利用する。ただし、上流依存があることは各基盤が同時かつ即時に利用不能になることを意味しない。既存 ID、既存レコード、仕様や複製が残存しても、新規採番、公式訂正、選定、推定又は統合・公開には継続運用が必要であり、データの残存と公式運営の継続は区別しなければならない。

また、入力情報源や参加主体が複数であることと、最終権限が分散していることも別である。NVD や KEV Catalog 等では外部情報の生成主体が複数存在しても、公式な分析方針、収載、統合又は公開を確定する権限は別に存在する。公開済み仕様やデータを複製できる場合も、公式な位置付けや、改訂、訂正又は選定の権限まで複製されるとは限らない。

EUVD や JVN iPedia 等の地域的・制度的基盤は供給経路と付加価値を多様化するが、共通の上流基盤への依存まで自動的に解消するものではない。このため RQ2 に対しては、どの機能がどの上流要素を必要とし、その意味、公式性、更新及び配信をどの主体が確定するかを三層で追跡することが重要となる。

5.3 6 評価軸から見た持続性の特徴

第 4 章の結果は、6 評価軸を一つの総合点へ集約するのではなく、独立した特性の組合せとして読む必要があることを示した。利用範囲は採用の広がり、機能的重要性は停止・劣化時の固有影響、提供継続性は提供を維持・回復する仕組み、主体集中度は支配領域への集中、代替可能性は外部手段による機能的置換、相互運用性は交換・併用・切替えの摩擦をそれぞれ評価する。このため High は一律に「良い」又は「悪い」を意味しない。

例えば、主体集中度 High と相互運用性 High は両立し得る。データ形式や識別子が文書化され、独立した下流実装と交換可能であっても、何を公式に追加、選定、改訂又は公開するかを確定する権限は集中し得る。同様に、相互運用性 High と代替可能性 Medium も両立する。情報を機械的に交換・併用できても、元の中核機能を同じ対象範囲、意味、品質、適時性及び公式性で置き換えられるとは限らない。また、提供継続性 Medium は「継続性が低い」ことを意味しない。正式な提供基盤や運用実績を確認できる一方、High を確定するための制度化、復旧・承継、資源又は透明性等の条件が揃わない状態を含む。Unknown も Medium 相当を意味せず、必要な公開根拠から区分境界を確定できないこと自体を評価上の情報として残したものである。

EPSS の補助評価単位では、日次生成・配信とモデル・方法論の保守で評価結果が分かれ、同一基盤内部でも持続性上の特徴が均一でないことが確認された。したがって RQ3 に対しては、各軸を独立に保持し、その組合せから持続性を解釈することが重要である。

5.4 地政学的変動下における残存性と代替性

地政学的変動は独立した第 7 評価軸ではなく、政策変更、予算、制度、アクセス条件等と同様に停止・劣化を生じさせ得る原因候補として扱う。本研究で問うのは、その蓋然性ではなく、供給制約が生じた場合にどの機能が残り、何が失われ、どこまで既存手段で補完できるかである。

第一に、残存性と代替可能性は異なる。公開済み仕様、既存データ、ローカル複製又は独立実装が残れば、過去情報の参照や既存環境での処理を継続できる場合がある。しかし、それらが残ることは、新規採番、公式訂正、辞書更新、悪用選定、標準改訂、日次予測又は固有エンリッチメントを同じ意味と適時性で継続できることを意味しない。したがって、データ複製が残ることと、公式運営が継続することも別である。

第二に、この差には時間軸がある。CVSS のような標準・仕様型では、公式保守が停止しても公開済み仕様と既存実装によって現行版を一定期間利用し得る。他方、CVE、Official CPE Dictionary、KEV Catalog のような継続更新型では、新規事象を処理できなければ時間経過とともに既存情報が陳腐化する。NVD、EUVD、JVN iPedia 等のエンリッチメント型では上流情報が残っても固有の付加・整理・配信機能が失われ得る。EPSS のような予測サービスでは、方法論や過去スコアが残っても、日次生成が止まれば予測値の鮮度は維持できない。したがって、同じ「残る」という状態でも、残存する能力と影響の顕在化時期は機能によって異なる。

第三に、代替は完全代替、部分代替、補完、併用及び手作業による回避を区別する必要がある。既存の別基盤や上流情報によって主要部分を補える場合でも、元の対象範囲、意味、品質、適時性又は公式性まで単一手段で維持できる

© 2026 Information Processing Society of Japan

とは限らない。このため、残存物が存在することや他の基盤へ接続できることだけから、元の中核機能を独立して代替できるとは判断できない。

第四に、EUVD や JVN iPedia 等の地域的・制度的基盤は、供給経路、言語、地域情報及び付加価値を多様化し、部分的な補完可能性を高める。一方で、共有する CVE 等の上流識別子や既存標準への依存は残り得る。したがって、地域的・制度的な基盤が増えることと、共通の上流基盤への依存から独立することは異なる。同じ上流基盤を共有する複数基盤は、見かけ上の多様化ほど独立した代替関係ではない場合がある。

以上から、地政学的変動下の持続性は、対象そのものが存続するかではなく、供給制約後にどの層の能力が残り、どの機能を複数の部分代替や補完手段で縮退運用できるかとして捉える必要がある。

5.5 日本にとって維持すべき能力と補完関係

日本に必要なのは、CVE、NVD、EPSS 等 8 対象すべての国内版を一式構築することではない。国際的な共通基盤との接続を維持しながら、供給制約時にも必要な機能を国内で保持・補完し、縮退運用できる能力を確保することである。

国内側では、既存仕様・データを保持して供給制約直後にも参照・処理できること、日本語や国内製品・脆弱性情報等を整理・統合できること、複数情報源を共通識別子で突合して必要な判断材料を再構成できること、異なる形式・版・項目を機械可読に変換・交換できることが重要となる。また、上流の更新、API 又はエンリッチメントの一部が失われても、取得済み情報、別経路、複数情報源及び必要に応じた手作業を組み合わせ、中核的な脆弱性管理を縮退させながら継続できる能力が必要となる。

同時に、国際的な識別子、標準及び上流情報との接続を維持することも不可欠である。国内独自体系へ閉じるのではなく、CVE 等の共通参照性を維持し、国際的な標準や公共的基盤の保守・ガバナンスへ関与できる能力を持つことは、国内化とは異なる形で持続性を支える。ここから特定の参加制度や資金拠出方法までを導くことはできないが、国際的基盤を利用するだけでなく維持に関与できる能力の重要性は示唆される。

JVN / JVN iPedia は、この構造における国内補完層として位置付けられる。日本語情報や国内固有情報を付加し、国内利用者が利用可能な形へ整理・配信することに価値がある一方、CVE、NVD、CVSS、Official CPE Dictionary 等の国際的な上流基盤を完全代替するものではない。したがって、日本にとっての持続性は海外依存をゼロにすることではなく、国内保持、国際接続、国内固有情報の補完、複数情報源の統合、機械可読な交換及び縮退運用を組み合わせることにある。

5.6 評価方法の有効性と限界

本方法は、公共的基盤を名称単位ではなく 8 機能へ整理し、依存関係を機能・基盤・提供主体の三層に分け、必要な場合だけ補助評価単位へ分解することで、同一基盤内部の差を保持した。また、S1〜S7 と残存機能を組み合わせることで、停止を即時の全面喪失と同一視せず、6 軸を独立評価して総合点化を避け、Unknown / Not Applicable によって根拠不足を推測で埋めなかった。EV-01 / EV-02 の独立評価と合議も、一つの評価結果のみで最終判定を確定せず、独立した評価結果とその根拠を照合し、判断過程を追跡可能にする構造として機能した。ただし、これらは客観性又は完全な再現性を保証するものではなく、分析上の区別を明示し、恣意性を抑えるための方法として位置付けられる。

限界として、本研究は公開情報に依存し、詳細評価を 8 対象に限定している。H/M/L は対象横断比較のための粗い区分であり、評価単位をどこで分割するかにも分析者判断が残る。独立した 2 系列の評価を用いたが、系列間の一致度を統計的指標で検証しておらず、第三者による再適用も行っていない。また、結果は 2026 年 08 月 05 日時点の状態であり、提供主体、ガバナンス、API、利用状況等の変化によって更新を要する。代替可能性と相互運用性も、公開情報から把握可能な機能的条件を評価したものであり、個々の組織における実際の移行時間、人員、契約、費用等を定量評価していない。したがって、本方法は完成された汎用標準ではなく、公共的基盤の機能、依存関係及び持続性の差を探索的に整理する方法として解釈する必要がある。

6. 結論

本研究は、脆弱性管理を支える公共的基盤を機能、依存関係及び持続性の観点から整理し、CVE Program、Official CPE Dictionary、CVSS、NVD、KEV Catalog、EPSS、EUVD 及び JVN iPedia の 8 対象へ試行的に適用した。調査基準日は 2026 年 08 月 05 日である。

RQ1「脆弱性管理を支える公共的基盤は、どのような機能から構成されるか」に対して、脆弱性識別、製品・資産対応付け、技術評価、情報エンリッチメント、悪用観測、悪用可能性予測、リスク優先順位付け・意思決定支援、情報流通・機械可読交換の 8 機能として整理した。8 対象と 8 機能は一対一ではなく、複数基盤が分業しながら接続する。

© 2026 Information Processing Society of Japan

RQ2「各機能およびそれを提供する基盤の間には、どのような依存関係が存在するか」に対して、機能間依存、基盤間依存、提供主体への依存の三層が重なって成立することを示した。共通の上流基盤への依存、入力主体の分散と公式権限の分散、公開済みデータ・仕様の複製と公式な更新・訂正等の継続は、それぞれ区別する必要がある。

RQ3「脆弱性管理を支える基盤を、公共的基盤としてどのような観点から評価できるか」に対して、利用範囲、機能的重要性、提供継続性、主体集中度、代替可能性、相互運用性の 6 軸を独立して評価した。H/M/L は総合点化せず、根拠不足又は解消不能な相反は Unknown、論理的な非該当は Not Applicable として区別し、根拠不足を Medium で代用しない。

地政学的変動は独立した第 7 評価軸ではなく、供給制約や停止・劣化を生じさせ得る原因として扱う。持続性評価では、残存性と代替可能性、データ・仕様の複製と公式運営の継続、地域的・制度的な多様化と共通の上流基盤への依存からの独立を区別する必要がある。

日本に必要なのは 8 対象すべての国内複製ではなく、国際的な識別子・標準及び上流情報との接続を維持しつつ、必要な仕様・データの国内保持、国内固有情報の補完、複数情報源の統合、機械可読な交換及び供給制約時の縮退運用を組み合わせることである。JVN / JVN iPedia は国内補完層として有用であるが、国際的な上流基盤の完全代替ではない。

本研究は、8 対象への試行適用に基づく探索的研究であり、普遍的な評価フレームワークの確立を主張するものではない。公開情報への依存、対象数、H/M/L の粗さ、評価単位分割に残る分析者判断、系列間の一致度を統計的指標で検証していないこと、2026 年 08 月 05 日時点のスナップショットであること、実際の移行時間・費用・人員・契約条件等を定量評価していないことが主な限界である。今後は、対象及び時点を広げた適用、第三者による再適用、実際の移行負担の検証が必要である。

参考文献

[1] 井上 圭: "地政学的変動下における米国外脆弱性情報の評価と課題、示唆：持続可能なエコシステムへの提言", CSS 2025, 2025.
[2] National Institute of Standards and Technology, “NVD News,” 2024/02/13, 2024/04/25, 2024/05/29, 2024/11/13 付更新, https://www.nist.gov/itl/nvd/nvd-news
[3] National Institute of Standards and Technology, “National Vulnerability Database,” 2025/03/19, 2026/04/15, 2026/05/28, 2026/06/17 付更新, https://www.nist.gov/itl/nvd
[4] Frank Konkel, “CISA extends MITRE-backed CVE contract hours before its lapse,” Nextgov/FCW, 2025/04/16, https://www.nextgov.com/cybersecurity/2025/04/cisa-extends-mitre-backed-cve-contract-hours-its-lapse/404601/
[5] CVE Foundation, “CVE Foundation Launched to Secure the Future of the CVE Program,” 2025/04/16, https://www.thecvefoundation.org/newsroom/posts/2025-04-16-launch
[6] European Union Agency for Cybersecurity, “Consult the European Vulnerability Database to enhance your digital security!,” 2025/05/13, https://www.enisa.europa.eu/news/consult-the-european-vulnerability-database-to-enhance-your-digital-security
[7] IPA「脆弱性対策情報データベース JVN iPedia」公開日記載なし, https://jvndb.jvn.jp/
[8] IPA「MyJVN API」公開日記載なし, https://jvndb.jvn.jp/apis/
[9] Forum of Incident Response and Security Teams, “CVSS v4.0 User Guide,” 公開日記載なし, https://www.first.org/cvss/v4.0/user-guide
[10] Cybersecurity and Infrastructure Security Agency, “Reducing the Significant Risk of Known Exploited Vulnerabilities,” 公開日記載なし, https://www.cisa.gov/known-exploited-vulnerabilities-catalog/reducing-significant-risk-known-exploited-vulnerabilities
[11] Forum of Incident Response and Security Teams, “Exploit Prediction Scoring System (EPSS): Frequently Asked Questions,” 公開日記載なし, https://www.first.org/epss/faq
[12] Cybersecurity and Infrastructure Security Agency, “Transforming the Vulnerability Management Landscape,” 2022/11/10, https://www.cisa.gov/news-events/news/transforming-vulnerability-management-landscape
[13] Cybersecurity and Infrastructure Security Agency, “BOD 26-04: Prioritizing Security Updates Based on Risk,” 2026/06/10, https://www.cisa.gov/news-events/directives/bod-26-04-prioritizing-security-updates-based-risk
[14] Google Project Zero, “From Naptime to Big Sleep: Using Large Language Models To Catch Vulnerabilities In Real-World Code,” 2024/11/01, https://googleprojectzero.blogspot.com/2024/10/from-naptime-to-big-sleep.html
[15] Defense Advanced Research Projects Agency, “AI Cyber Challenge Marks Pivotal Inflection Point for Cyber Defense,” 2025/08/08, https://www.darpa.mil/news/2025/aixcc-results
[16] CVE Program Overview: https://www.cve.org/about/overview
[17] CVE Program Structure: https://www.cve.org/programorganization/Structure
[18] CNA Operational Rules: https://www.cve.org/resourcessupport/allresources/cnarules
[19] CVE Services: https://www.cve.org/allresources/cveservices
[20] CVE JSON 5 Schema Documentation: https://cveproject.github.io/cve-schema/schema/docs/
[21] NVD CVE Process: https://nvd.nist.gov/general/cve-process
[22] NVD, Vulnerability APIs: https://nvd.nist.gov/developers/vulnerabilities
[23] NVD, Data Feeds: https://nvd.nist.gov/vuln/data-feeds
[24] Forum of Incident Response and Security Teams, “Exploit Prediction Scoring System (EPSS)”: https://www.first.org/epss/
[25] Forum of Incident Response and Security Teams, “How EPSS Works”: https://www.first.org/epss/how-it-works
[26] Forum of Incident Response and Security Teams, “Get the Data”: https://www.first.org/epss/data
[27] IPA「脆弱性対策情報データベース JVN iPedia の登録状況 [2026 年第 1 四半期]」: https://www.ipa.go.jp/security/reports/vuln/jvn/ipedia2026q1.html
[28] IPA「脆弱性対策情報データベース JVN iPedia の登録状況 [2026 年第 2 四半期]」: https://www.ipa.go.jp/security/reports/vuln/jvn/ipedia2026q2.html

© 2026 Information Processing Society of Japan